College Operations Copilot — System Design

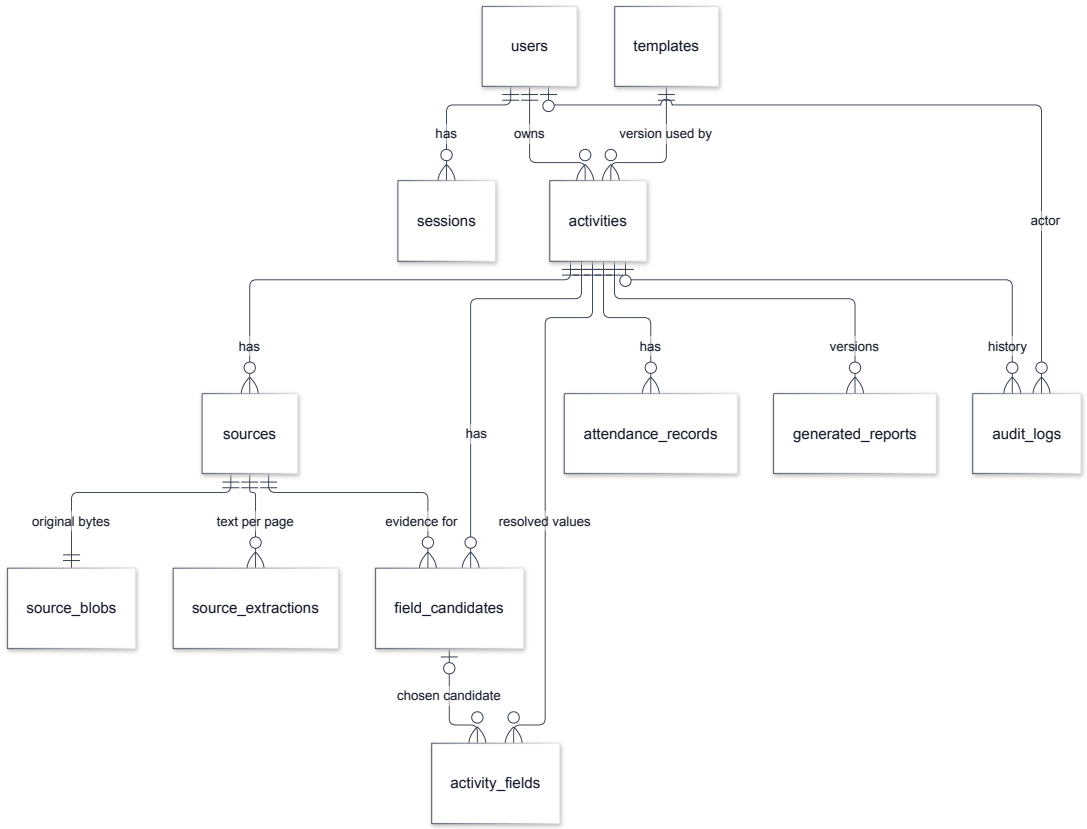
Engineering reference for the implemented system · Version 1.0 · 29 September 2026 · software at commit `7119b13`

> Everything in this document describes **implemented code**, unless it is marked `FUTURE`. Status labels: IMPLEMENTED | OPTIONAL · OFF BY DEFAULT | FUTURE. Verification: 90 Vitest tests (unit, Postgres integration, permissions, exports, two real reference cases) and 6 Playwright end-to-end tests against the production build.

1. System components

Layer	Module	Responsibility
UI (browser)	`src/app/(app)/**`, `src/components/*`	Dashboard, Activities, Create Activity, 7-tab workspace, Documents viewer, Reports, Templates, Audit Log, Settings, print view
Browser extraction	`src/lib/extraction/browser.ts`, `layout.ts`	pdf.js text layer with geometric line rebuild; tesseract.js OCR for pages with fewer than 200 characters
Client exports	`src/lib/exports/packet.ts`	Compiled packet PDF and evidence ZIP, assembled from authorised endpoints
API	`src/app/api/**/route.ts` (20 files)	Session check, same-origin check, zod validation, rate limits, error mapping (`errors.ts`)
Auth	`server/auth-core.ts`, `server/auth.ts`	bcrypt passwords, hashed session tokens, cookie handling
Activity service	`server/activities.ts`	Access control, fields, sources, extraction ingest, attendance, reports, approval, status
Parser	`extraction/parser.ts`, `attendance.ts`	Deterministic candidate extraction per document kind; attendance row drafts
Resolution	`fields/resolve.ts`, `normalize.ts`	Type normalisation, conflict detection, candidate ranking
Reconciliation / gate	`reconciliation.ts`, `readiness.ts`	Count checks; blocking issues and warnings
Reports / exports	`reports/build.ts`, `exports/docx.ts`, `exports/pdf.ts`, `server/exports.ts`	Report content; DOCX, PDF, CSV, JSON manifest
Templates	`templates/schema.ts`, `kdk-mech-v1.ts`, `seed.ts`, `server/templates.ts`	zod-validated, versioned JSON templates
AI adapter	`ai/provider.ts`, `server/ai-extraction.ts`	OPTIONAL `AIProvider` interface; deterministic default; OpenAI-compatible grounded extraction
Data	`db/migrations/001_init.sql`, `scripts/migrate.ts`	PostgreSQL schema; migration runner that also seeds the templates

2. Database entities



Legend Implemented (verified in code and tests) → arrows show data / control direction; dotted = optional or proposed

Entity relationships (13 tables, db/migrations/001_init.sql)

Table	Key columns	Purpose
`users`	email (unique, case-insensitive), role `faculty/admin`, password_hash, is_active	Accounts
`sessions`	token_hash (SHA-256), expires_at	Server-side sessions
`rate_limit_events`	bucket, key, created_at	Fixed-window rate limiting
`templates`	slug, version, definition (jsonb), is_active	Versioned report templates
`activities`	owner_id, template_id, status, fields_updated_at, reconciliation_ack, approved_by, approved_at	One documented activity
`sources`	kind, filename, mime_type, size_bytes, sha256 (unique per activity), page_count, extraction_status	Uploaded document metadata
`source_blobs`	data (bytea)	Original bytes, stored unmodified
`source_extractions`	page, method `pdf_text/ocr`, engine, text, confidence	Page text with its method
`field_candidates`	field_key, value, normalized, page, confidence, method, rule, snippet	Every value found in any source
`activity_fields`	value, status, source_id, source_page, confidence, candidate_id, original_value, edited_by, edited_at, note	The resolved value per field
`attendance_records`	serial_no, student_name, gender, gender_raw, method, confidence, issues[], verified	Attendance rows

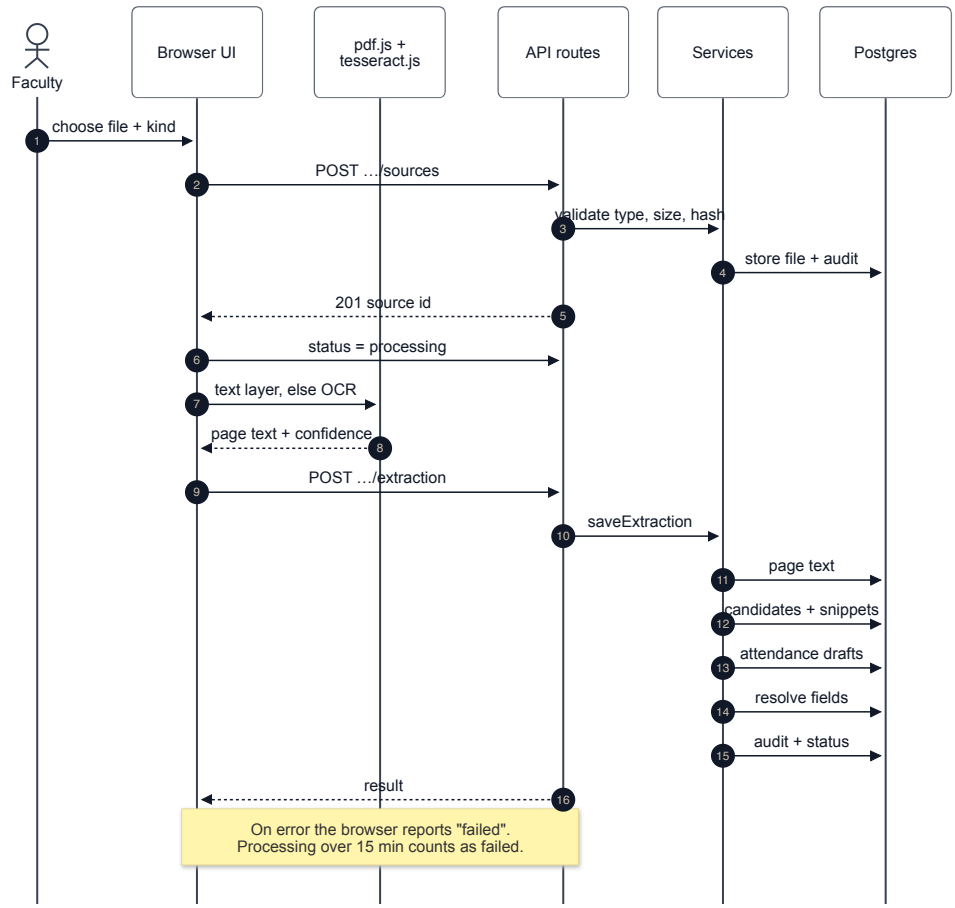
Table	Key columns	Purpose
`generated_reports`	report_type, version, content (jsonb), generator	Versioned report content
`audit_logs`	actor_id, activity_id, action, entity_type, entity_id, details (jsonb)	Append-only history

3. APIs

All mutating routes require a session **and** a same-origin `Origin` header. Bodies are validated with zod, and access checks happen in the service layer.

Method	Route	Purpose
POST	`/api/auth/login` · `/api/auth/logout`	Sign in (rate limited per email and IP) / sign out
POST	`/api/account/password`	Change own password (rate limited)
POST	`/api/activities`	Create activity with optional user-entered fields
POST	`/api/activities/{id}/sources`	Upload a document (multipart; rate limited)
PATCH · DELETE	`/api/sources/{id}`	Edit caption or source info · remove a document
GET	`/api/sources/{id}/file`	Stream the original file to an authorised user (`private, no-store`)
POST	`/api/sources/{id}/extraction-status`	Browser reports `processing` or `failed`
POST	`/api/sources/{id}/extraction`	Browser submits per-page text; server re-runs the parser
POST	`/api/activities/{id}/fields/{key}`	`set` value · `confirm` extracted value · `choose` candidate
POST	`/api/activities/{id}/attendance`	`add` · `update` · `delete` · `verify_all` · `import_csv`
POST	`/api/activities/{id}/reconciliation-ack`	Record a written acknowledgement of a count mismatch
POST	`/api/activities/{id}/reports`	Generate a new version of all three reports
POST	`/api/activities/{id}/workflow`	`approve` · `archive` · `reopen` (admin, with reason)
GET	`/api/activities/{id}/export?type=&format=`	Activity/Detailed/Attendance report as PDF or DOCX; attendance CSV; JSON manifest (audited)
POST	`/api/activities/{id}/ai-extract`	OPTIONAL grounded LLM extraction; 409 when not configured
POST · PATCH	`/api/admin/users` · `/api/admin/users/{id}`	Create user · activate, deactivate, change role, reset password (admin)
PUT	`/api/templates/{id}`	Save an edited template as a new version (admin; validated)
GET	`/api/health`	Database connectivity and migration state; no configuration values revealed

4. Upload and OCR flow



Legend Implemented (verified in code and tests) Human control point

→ arrows show data / control direction; dotted = optional or proposed

Upload and extraction sequence

Step	Rule (implemented)
Upload validation	Type sniffed from magic bytes (PDF, JPEG, PNG); extension must match; 0 < size ≤ 4 MB; PDF must parse (pdf-lib); PNG must be complete; SHA-256 duplicate check per activity; at most 40 files per activity; filename sanitised
Text layer	pdf.js `getTextContent`. Lines are rebuilt from item coordinates, because PDF generators do not reliably mark line ends. A page with at least 200 non-space characters counts as having a text layer.
OCR	tesseract.js 7 (English, LSTM, PSM 4), page rendered at **1224 px** wide. This width was chosen by measurement on the two reference packets: 18/18 fields correct each at 1100–1300 px, dropping to 16/18 at 1700 px.
Photographs	Stored as evidence; never OCR'd; nothing is read from them.
Attendance	OCR rows are drafted as `method = ocr`, `verified = false`. Gender is taken only from the gender cell (exact, or a close OCR misspelling: ≤ 1 edit from “male”, ≤ 2 from “female”), never from names.

5. Provenance model

A **field candidate** is a single piece of evidence: `{field_key, value, normalized, source_id, page, confidence, method, rule, snippet}`.

Candidate source (rule)	Rule confidence
Report table, label and value on the same line	0.90

Candidate source (rule)	Rule confidence
Report table, multi-line narrative cell	0.85
Detailed report topic / date line	0.85
Notice header date (→ `notice_date`, never the activity date)	0.85
Notice body date or time	0.80
Detailed report body / impact paragraph	0.75
Attendance sheet date	0.70
Notice venue / first quoted phrase	0.60 / 0.55
Value rebuilt from a wrapped table cell; poster date, title or association	0.50
Label matched approximately (OCR slip)	capped at 0.75, rule suffix `:fuzzy_label`
LLM value with a verified quote OPTIONAL	0.60, method `llm`

Final confidence = the lower of the rule confidence and the page's OCR confidence ÷ 100 (text-layer pages count as 1.0).

Field state (`activity_fields`) records the chosen value, its source and page, the candidate id, the status (`extracted` · `user_entered` · `missing` · `conflicting`; `inferred` exists in the schema but is never produced), and on edit the `original_value`, `edited_by`, `edited_at` and `note`.

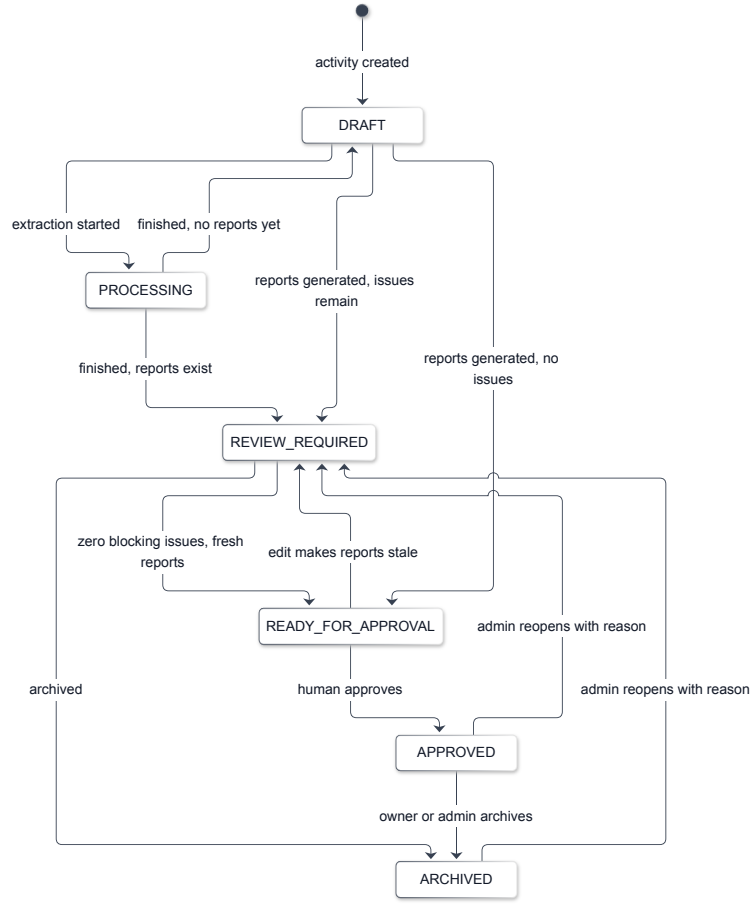
6. Conflict model

1. A value the user entered or confirmed (`edited_by` set) is never overwritten by re-extraction.
2. A field with no candidates is `missing` with value `null`.
3. `date`, `time` and `integer` fields: more than one distinct normalised value → `conflicting` with value `null`. **No automatic resolution.**
4. Text fields: candidates are ranked by confidence band (≥ 0.8 first), then the template's `sourcePriority`, then page. The top candidate is used; the others are listed as alternatives.
5. A reviewer resolves a conflict by choosing a candidate (provenance kept) or entering a value (original kept). Both actions are audited.

7. Report model

- **Template.** JSON, validated by zod. It defines the fields (key, label, type, required flag, parser aliases), the activity report's title lines, detail rows, narrative rows and signatories, the detailed report's letterhead, date line, topic, description and impact sections, the attendance fields, the packet section order and the source priority. Placeholders (`{field_key}`) must reference fields that exist.
- **Builders.** Output is pure data (`ActivityReportContent`, `DetailedReportContent`, `AttendanceSummaryContent`).
  - A missing or conflicting value renders as **“Not provided”**; signature lines render blank.
  - The detailed-report description, when not supplied, is drafted *only* from the template sentence plus existing fields, and records which fields it used. Impact Analysis falls back to the Outcomes text verbatim.
- **Versions.** Every generation stores a new version per report type. Reports older than the latest field change are **stale** and block approval.
- **Renderers.** DOCX (docx), PDF (pdf-lib, Times; unsupported glyphs replaced and disclosed), CSV (formula-injection safe), JSON manifest. The packet PDF and ZIP are built in the browser. Exports before approval carry a “DRAFT — not yet approved” footer.

8. Approval model



Activity status model

Blocking issue (prevents approval)	Warning (shown only)
Any `conflicting` field	Reconciliation UNVERIFIED (counts agree, rows not all verified)
Required field missing	No attendance rows recorded
Extracted value below 0.8 confidence, not confirmed	Extraction failed for a document
Reconciliation FAIL without a valid acknowledgement (the acknowledgement is invalidated if counts change)	Reconciliation FAIL that has been acknowledged
Reports never generated, or stale	
Extraction still running (processing for more than 15 min is treated as failed)	

Approval requires an authenticated user and zero blocking issues. It records `approved_by` and `approved_at` and makes the activity read-only. Only an administrator can reopen it, and must give a reason.

9. Audit model

`audit_logs` is append-only and written in the same database transaction as the change it records. Details hold identifiers, field keys and values truncated to 200 characters — never document text, passwords or tokens.

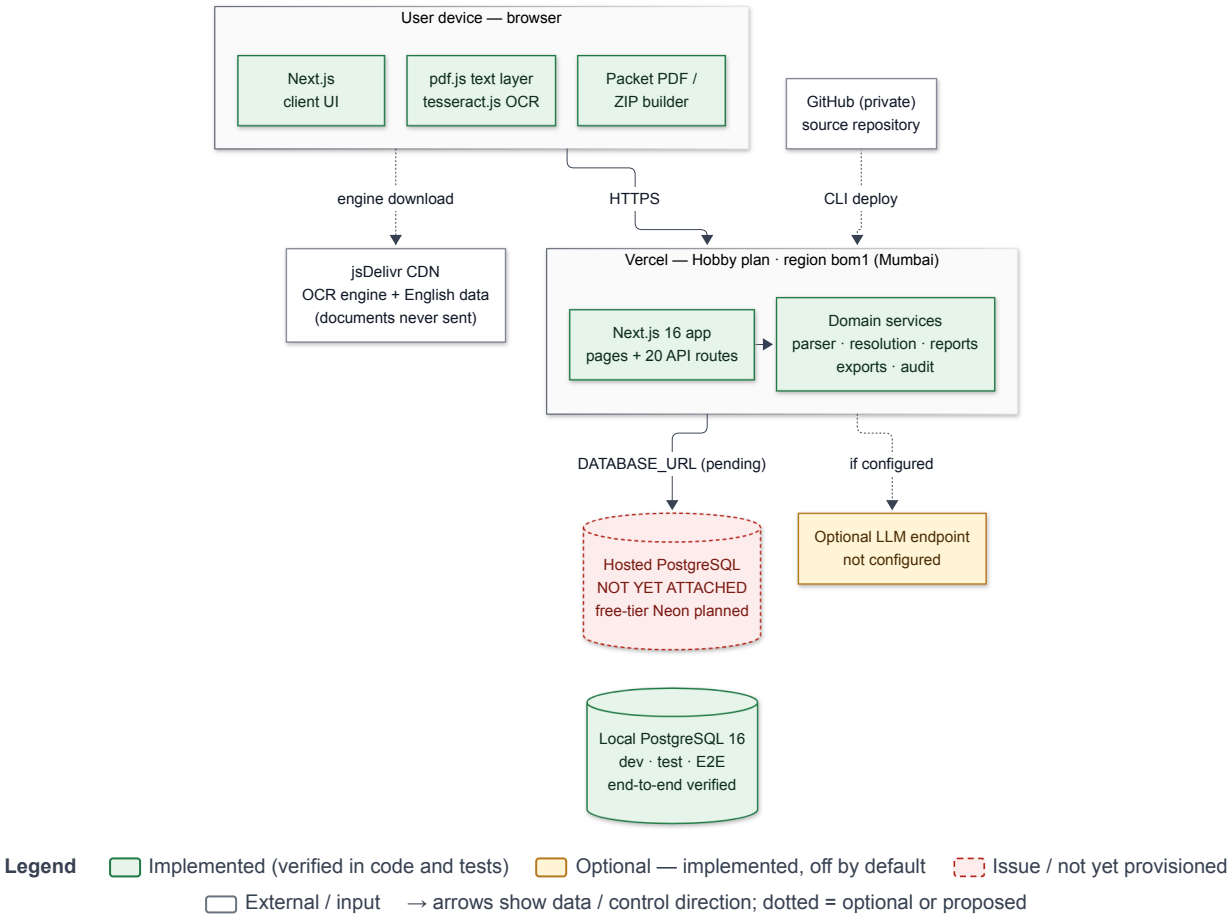
The 27 actions:

- **Auth:** `auth.login`, `auth.logout`
- **Activity:** `activity.created`, `activity.approved`, `activity.archived`, `activity.reopened`
- **Documents:** `source.uploaded`, `source.deleted`, `source.caption_updated`
- **Extraction:** `extraction.completed`, `extraction.failed`, `ai.extraction`
- **Fields:** `field.edited`, `field.confirmed`, `field.conflict_resolved`
- **Attendance:** `attendance.row_added`, `attendance.row_updated`, `attendance.row_deleted`, `attendance.rows_verified`, `attendance.csv_imported`, `reconciliation.acknowledged`
- **Reports:** `report.generated`, `export.downloaded`
- **Administration:** `template.saved`, `user.created`, `user.updated`, `account.password_changed`

10. Security boundaries

Boundary	Control
Browser → API	httpOnly, SameSite=Lax session cookie (Secure in production); same-origin `Origin` check on every mutation; zod validation
Identity	bcrypt (cost 11); 256-bit tokens stored as SHA-256; constant-work login for unknown emails; admin-provisioned accounts only
Authorisation	Service-layer check on every read and write: faculty see only their own activities, admins see all; unauthorised access returns 404; approved activities are read-only
Files	Magic-byte typing; 4 MB limit; files stored in the database (no public URLs); served `private, no-store`, `nosniff`
Abuse	Postgres-backed rate limits: login, upload, password change, LLM extraction
Secrets	Only in environment variables; `.env*` git-ignored; `/api/health` exposes status only; errors are logged without request bodies
Private data	Real reference documents are git-ignored and excluded from deployments (`.vercelignore`); OCR runs in the browser

11. Deployment topology



Deployment topology as verified on 29 Sep 2026

Environment	State
Local (dev / test / E2E)	PostgreSQL 16; full workflow verified with Playwright against the production build
Vercel production	Hobby plan, region `bom1`, serving commit `bcd9075`. `vercel-build` runs migrations when `DATABASE_URL` is set. **No database is attached yet.** Later deployments are **blocked** by Vercel team access (`TEAM_ACCESS_REQUIRED`).
Configuration	`DATABASE_URL` (required); `AI_PROVIDER`, `AI_BASE_URL`, `AI_MODEL`, `AI_API_KEY` (optional, unset)

12. Failure handling

Failure	Behaviour (implemented)
Empty, oversized, wrong-type, corrupt or duplicate upload	Rejected with a specific message (400 / 409 / 413 / 415 / 422)
Page text cannot be extracted	Source marked `failed` with “Could not extract text from this file.”; the user enters details manually
OCR engine fails in the browser	Browser posts `failed` with the message; the user can re-run extraction
Browser closed mid-extraction	`processing` for more than 15 min is treated as failed
Handwriting unreadable	Rows drafted as unverified with issues listed (“Gender not readable”, “possible OCR error”)
Conflicting dates, times or counts	Field left empty, marked `conflicting`; approval blocked

Failure	Behaviour (implemented)
Participant totals do not reconcile	Reconciliation FAIL; approval blocked until corrected or acknowledged
Report requested before generation	409 “Generate the reports first.”
Approval with open issues	409 “Report cannot be approved until required fields are resolved.” plus the issue list
Unauthorised access	401 (no session) · 403 (cross-origin or not admin) · 404 (another user's record)
Database not configured	Pages redirect to sign-in with a notice; APIs return 503 (fixed in `6f89224`, not yet deployed)
LLM not configured or ungrounded	409 when not configured; unquoted or unsupported suggestions discarded and counted
Unexpected server error	Generic 500 message; only the error name and message are logged

FUTURE Object storage for files larger than 4 MB, a background job queue, per-page document classification, multi-department sharing, and an agent service principal with an allow-listed toolset. None of these is built.